

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- State the NIST SP 800-145 formal definition of cloud computing from memory.
- Differentiate IaaS, PaaS, and SaaS by what each service model requires the customer to secure.
- Explain why 'more provider control' does not automatically mean 'less customer risk.'
- Map at least two real-world service examples to each of the three service models.
- Apply the shared-responsibility spectrum to a hypothetical deployment scenario.

Introduction

Informal descriptions of 'the cloud' are common and imprecise, and that imprecision is exactly where security gaps form: unassigned responsibilities, misconfigured contracts, and inaccurate compliance assessments. This guide anchors you to the formal NIST definition and the three service models it implies, so that your professional vocabulary matches the one the exam, and serious cloud governance work, actually uses.

The three service models, IaaS, PaaS, and SaaS, are not just labels for different products. Each one draws the shared-responsibility line in a different place, and that line determines exactly which controls your organization must implement itself versus which it can reasonably expect the provider to have already covered.

This guide expands the lecture's ride-sharing analogy into a working framework you can apply directly: for any cloud service in front of you, identify its service model first, then use that model to reason about where your security obligations begin.

Core Concepts Explained

NIST SP 800-145 definition

Definition: Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources that can be rapidly provisioned and released with minimal management effort or provider interaction.

Business relevance: This definition is the basis for how regulators, auditors, and contracts distinguish 'cloud computing' from generic outsourced or managed hosting.

Cloud Security Practitioner relevance: You need to be able to test any service against this definition and determine whether it is genuinely cloud computing or simply an internet-delivered service.

Real-world example: A vendor advertises a 'cloud-hosted' application, but provisioning a new instance requires a support ticket and a week of lead time; measured against the NIST definition, this fails the on-demand self-service criterion.

Risks or limitations: Misclassifying a managed-hosting arrangement as cloud computing can lead to applying the wrong compliance framework or contractual expectations.

Infrastructure as a Service (IaaS)

Definition: The provider delivers raw compute, storage, and network infrastructure; the customer manages the operating system, middleware, applications, data, and associated security controls.

Business relevance: IaaS gives an organization maximum flexibility and control, at the cost of owning most of the security stack directly.

Cloud Security Practitioner relevance: As a practitioner, expect to own OS patching, network configuration, and application-layer security for any IaaS workload you are asked to assess.

Real-world example: Amazon EC2, Azure Virtual Machines, and Google Compute Engine are all IaaS offerings where the customer manages everything above the hypervisor.

Risks or limitations: Under-resourced teams sometimes deploy IaaS workloads without building the patching and configuration discipline that this model requires of the customer.

Platform as a Service (PaaS)

Definition: The provider manages infrastructure, operating system, and runtime; the customer deploys and manages applications and their data.

Business relevance: PaaS reduces operational overhead significantly, letting teams focus on application logic rather than infrastructure maintenance.

Cloud Security Practitioner relevance: Your security focus in PaaS environments narrows to application-layer controls, secure coding practices, and data protection, since the provider owns the layers below.

Real-world example: Google App Engine and AWS Elastic Beanstalk let developers deploy code without managing servers or patching operating systems.

Risks or limitations: Teams sometimes assume PaaS removes all their security responsibility, when application-layer vulnerabilities remain entirely the customer's problem.

Software as a Service (SaaS)

Definition: The provider manages the entire stack, including the application itself; the customer's responsibility narrows to data governance, identity and access management, and configuration.

Business relevance: SaaS minimizes technical overhead but concentrates residual risk into a small number of high-leverage areas: who has access, and how the application is configured.

Cloud Security Practitioner relevance: In SaaS environments, your work as a practitioner is almost entirely about access governance and configuration review, since there is no infrastructure to secure directly.

Real-world example: Salesforce, Microsoft 365, and Google Workspace are SaaS platforms where misconfigured sharing settings, not infrastructure flaws, are the dominant real-world risk.

Risks or limitations: Misconfigured SaaS applications account for a significant share of real-world cloud breaches, precisely because customers assume the provider has 'covered' security.

Practical Applications

The following scenarios show the three service models in a practical decision-making context.

Choosing a service model for a new internal tool

A team building a custom internal analytics tool weighs IaaS (full control, full responsibility) against PaaS (faster delivery, narrower security scope) and documents the trade-off explicitly as part of the architecture decision record.

SaaS access review

A GRC analyst runs a quarterly access review of the organization's SaaS applications, focused entirely on identity, permissions, and sharing configuration, since infrastructure and application security are outside the customer's control in this model.

Vendor risk questionnaire calibration

A security team customizes its vendor risk questionnaire based on service model: an IaaS vendor gets deep infrastructure and patching questions, while a SaaS vendor gets deep questions about data handling, access controls, and configuration options.

Best Practices

- **Identify the service model before evaluating any cloud service's security.** Every subsequent security question depends on knowing whether you are looking at IaaS, PaaS, or SaaS.
- **Never assume provider-managed layers are equally secure across services.** Verify provider security claims through certifications and audit reports rather than trusting marketing language.
- Build a standing internal reference sheet mapping your organization's actual services to their correct service model, so new team members do not have to rediscover this each time.

Common Mistakes and Misconceptions

Misconception: Assuming SaaS means 'nothing for us to secure.'

Correct approach: Recognize that identity, access management, and configuration remain fully the customer's responsibility even in SaaS.

Misconception: Confusing 'managed hosting' with genuine cloud computing.

Correct approach: Test any service against all elements of the NIST definition, especially on-demand self-service and rapid elasticity, before classifying it as cloud.

Misconception: Treating more provider control as automatically lower risk.

Correct approach: Recognize that risk simply shifts location, from infrastructure risk toward configuration and access-governance risk, as you move from IaaS to SaaS.

Table: Service Model Responsibility Matrix

Use this matrix to quickly locate where customer responsibility begins for any cloud service.

Layer	IaaS	PaaS	SaaS
Physical infrastructure / hardware	Provider	Provider	Provider
Hypervisor / virtualization	Provider	Provider	Provider
Operating system	Customer	Provider	Provider
Runtime / middleware	Customer	Provider	Provider

Application	Customer	Customer	Provider
Data governance & access management	Customer	Customer	Customer

How to use this: Data governance and identity/access management remain the customer's responsibility across all three models — this row never shifts.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A vendor requires customers to submit a support ticket and wait several business days for a new server instance, with fixed, non-scaling capacity. Based on the NIST definition, how should this service be classified?

- A) A. It is IaaS, because it delivers infrastructure.
- B) B. It is cloud computing, because it is delivered over the internet.
- C) C. It is a managed hosting arrangement, not cloud computing, because it lacks on-demand self-service and rapid elasticity.
- D) D. It is SaaS, because the vendor manages the servers.

Answer: C. It is a managed hosting arrangement, not cloud computing, because it lacks on-demand self-service and rapid elasticity.

Q2. An organization deploys an application on a PaaS platform. Which of the following remains the organization's responsibility?

- A) A. Patching the underlying operating system.
- B) B. Managing the hypervisor.
- C) C. Securing the application code and its data.
- D) D. Maintaining the physical data centre.

Answer: C. Securing the application code and its data.

Q3. Why does the lecture warn against assuming that more provider control automatically reduces customer risk?

- A) A. Because providers are generally less secure than customers.
- B) B. Because the customer always retains responsibility for access governance and configuration, regardless of service model.
- C) C. Because SaaS applications cannot be audited.
- D) D. Because provider control is irrelevant to security outcomes.

Answer: B. Because the customer always retains responsibility for access governance and configuration, regardless of service model.

Reflection Questions

1. Pick three cloud services your organization uses. Can you correctly classify each as IaaS, PaaS, or SaaS?
2. Where might your team be assuming a provider secures something that the shared-responsibility model actually leaves with you?
3. How would you explain the ride-sharing analogy to a colleague unfamiliar with cloud service models?

4. What would change in your security review process if a service moved from IaaS to SaaS?

Key Takeaways

- The NIST SP 800-145 definition is the formal, exam-tested standard for what qualifies as cloud computing.
- IaaS, PaaS, and SaaS each draw the shared-responsibility line in a different place along the technology stack.
- Data governance and identity/access management remain the customer's responsibility across all three service models.
- More provider control does not mean less customer risk; it means the risk shifts location.
- Misconfigured SaaS applications are a leading real-world cloud breach cause, driven by the misconception that the provider 'handles security.'

Recommended Next Actions

Put this lecture to work within the next seven days:

5. Classify every cloud service your team uses by service model and record it in a shared reference document.
6. Run a spot-check on one SaaS application's access and sharing settings this week.
7. Draft a one-sentence responsibility statement for one IaaS, one PaaS, and one SaaS service you use.